

Manual 55 — Governança de Terceiros, Fornecedores e Cadeia de Suprimentos de IA

Fonte controlada de publicação — pt-BR

Objetivo

Estabelecer uma estrutura prática para governar provedores de IA, modelos hospedados, agentes, plugins, conectores, servidores MCP, fornecedores de dados, subprocessadores e demais dependências da cadeia de suprimentos durante seleção, contratação, integração, operação, mudança, incidentes e saída. Requisitos legais, obrigações contratuais, expectativas de supervisão, estruturas voluntárias e orientações comunitárias devem permanecer claramente diferenciados.

TP-01 — Inventário e materialidade do provedor

Manter inventário completo de provedores, serviços, modelos, APIs, agentes, plugins, fontes de dados, dependências de hospedagem e quartas partes. Classificar por criticidade, autonomia, sensibilidade de dados, consequência, concentração, substituíbilidade e exposição regulatória.

TP-02 — Due diligence pré-contratual

Avaliar propriedade, viabilidade financeira, segurança, privacidade, governança de IA, histórico de incidentes, documentação, hospedagem, subcontratados, continuidade e disponibilidade de evidências antes da aprovação.

TP-03 — Garantia técnica e de segurança

Avaliar controle de acesso, isolamento de locatários, criptografia, gestão de vulnerabilidades, desenvolvimento seguro, controles contra abuso de modelo/API, logs, monitoramento, resposta a incidentes e evidência independente proporcional ao risco.

TP-04 — Privacidade e restrições de uso de dados

Documentar usos permitidos, treinamento/ajuste fino, retenção, exclusão, uso secundário, transferências transfronteiriças, dados sensíveis, subprocessadores e evidência de devolução/exclusão na saída.

TP-05 — Transparência de modelo, versão e mudança

Exigir identificação de versões materiais, mudanças de arquitetura, descontinuações, mudanças de comportamento, mudanças em controles de segurança e mecanismos de notificação suficientes para acionar revalidação interna.

TP-06 — Subprocessadores e quartas partes

Identificar dependências materiais e estabelecer visibilidade, aprovação, notificação, obrigações em cascata e controles de continuidade/saída com base em risco.

TP-07 — Hospedagem, residência e transferências

Mapear regiões de hospedagem, localizações de dados, planos de controle, backups, failover e mecanismos de transferência. Validar compromissos de residência com evidência técnica e contratual.

TP-08 — Identidade, autorização e ação delegada

Para agentes, plugins, conectores e provedores MCP/ferramentas, validar identidade, escopo de autorização, menor privilégio, autoridade delegada, limites transacionais, revogação e registros atribuíveis de ação.

TP-09 — Integridade da cadeia de suprimentos de IA

Avaliar proveniência de modelos, integridade de pacotes/dependências, artefatos, imagens, contêineres, bibliotecas, arquivos de modelo, adaptadores, conjuntos de dados, prompts, plugins e canais de atualização. Exigir controles contra substituição, adulteração, envenenamento e mudanças não autorizadas.

TP-10 — Controle contratual e direitos de evidência

Definir cláusulas de segurança, privacidade, restrições de uso de IA, acesso a auditoria/evidências, notificação de incidentes, mudança material, subcontratados, continuidade, término, devolução/exclusão de dados, cooperação e suporte regulatório quando aplicável.

TP-11 — Alegações de desempenho e segurança

Contestar alegações materiais de precisão, robustez, segurança, equidade, privacidade, certificações e benchmarks. Distinguir evidência verificada de afirmações do fornecedor.

TP-12 — Mudança e revalidação

Definir gatilhos de reavaliação: mudança de modelo/versão, novo subprocessador, mudança de hospedagem, falha de controle, incidente de segurança, mudança no uso de dados, mudança de propriedade, dificuldade financeira, regressão relevante ou novo requisito aplicável.

TP-13 — Coordenação de incidentes e violações

Definir prazos de notificação, compartilhamento de evidências, papéis de contenção, comunicações, cooperação forense, suporte regulatório e ações corretivas.

TP-14 — Risco de concentração e dependência sistêmica

Avaliar concentração em um provedor, dependências comuns de nuvem/modelo fundacional, bibliotecas compartilhadas, fornecedores de dados comuns, concentração regional e cenários de falha correlacionada.

TP-15 — Continuidade, portabilidade e saída

Validar backup/restauração, provedores alternativos, portabilidade de dados/modelos, formatos de exportação, migração, revogação de credenciais, exclusão de dados e remoção de dependências residuais.

TP-16 — Monitoramento contínuo

Monitorar sinais de risco, mudanças de serviço, avisos, ações regulatórias, mudanças de versão, degradação de SLA, incidentes, expiração de evidências e achados em aberto.

TP-17 — Exceções e risco residual

Registrar desvios aprovados, justificativa, controles compensatórios, responsável pelo risco, validade, gatilhos de revisão e evidência de encerramento.

TP-18 — Garantia pós-saída

Confirmar remoção de acesso, revogação de credenciais, devolução/exclusão de dados, descarte de modelos ou adaptadores quando aplicável, efeitos em subprocessadores, exceções de retenção e preservação de evidências.

Evidência exigida

EV-01 inventário/materialidade; EV-02 due diligence; EV-03 evidência de segurança/privacidade; EV-04 arquitetura/fluxos; EV-05 registro de quartas partes; EV-06 registro de versão/mudança; EV-07 matriz contratual; EV-08 contestação de alegações; EV-09 playbook de incidentes; EV-10 teste de continuidade/saída; EV-11 concentração; EV-12 monitoramento; EV-13 exceção; EV-14 término/exclusão.

Cenários

Mudança silenciosa de modelo; novo país/região; mudança de termos de uso de dados; ampliação de permissões; comprometimento de dependência comum; alegação não comprovada; indisponibilidade crítica sem migração; incidente coordenado; saída sem evidência completa de exclusão; concentração em provedor comum.

Regra de liberação

Alegações do fornecedor não são evidência independente sem comprovação. A publicação permanece fail-closed diante de defeitos substantivos de fontes, localização, artefatos, proveniência, renderização ou QA retida.